

GRC ASSESSMENT REPORT: WEEK 2 ASSIGNMENT

Building a Defensible GRC Capability for NexaLearn Digital Services Limited
GRC101 “ Introduction to GRC Engineering” Assignment 2 **Scenario & Lab**

Full Name	Adebukola Olanipekun
Registration Number	C11/26/CGRCE/17603
Email Address	bukolufemi@gmail.com
Cohort / Batch	11
Date Submitted	24TH JULY, 2026

Executive Summary

NexaLearn Digital Services Limited is a Nigerian education-technology company pursuing 40% learner growth, an ISO/IEC 27001 certification programme, and a fast-tracked AI-assisted admissions tool, while operating on an immature governance, risk and compliance (GRC) foundation. This report assesses NexaLearn's exposure using the evidence pack supplied, an identity and access review, a live incident timeline, and a third-party contract review and sets out a practical improvement package: a risk register, a compliance obligations map, a three-lines-of-defence and RACI model, a Common Control Framework (CCF), three control tests, an executive dashboard, and a prioritised 90-day action plan.

These are documented in full in the accompanying NexaLearn_GRC_Workbook.xlsx; this report summarises the analysis and the reasoning behind it.

The headline finding is that NexaLearn's most urgent exposure is not a single control gap but a pattern: controls exist on paper (an offboarding checklist, an MFA policy, a vendor assurance report) but are not consistently designed or operated to a defensible standard, and a confirmed personal-data breach remains unnotified to any regulator or learner at the time of this assessment. The recommendations in Section 7 and the Executive Decision Brief prioritise closing that notification gap first, then hardening privileged access, before addressing the medium-term compliance and AI-governance programme.

Phase 1 - LEARN: Understand Context and Exposure

1. Context, Stakeholder and Objective Analysis

NexaLearn's internal stakeholders include the Board and CEO (who set the Growth, Trust, Availability, Compliance and Innovation objectives), the Head of IT and two developers, a Finance Officer, an HR function, Internal Audit, and operational teams who currently regard compliance as "IT and Legal's job" rather than a shared responsibility. External stakeholders include roughly 18,000 learners across Africa Including about 600 residents in the EEA plus the payment gateway, the customer-support vendor, the outsourced software-development vendor, the cloud/Microsoft 365 platform, and eventual regulators (Nigeria's NDPC and EU supervisory authorities).

NexaLearn's critical processes are admissions and onboarding, training delivery and assessment, certification issuance, payment processing, customer support, identity and access management, vendor management, and incident response, all resting on a cloud-hosted learning platform, Microsoft 365, a payment gateway and third-party storage.

Three stakeholder conflicts stand out and must be governed deliberately rather than left to resolve informally.

First, the Board's 40% growth target conflicts with Trust and Compliance, because rapid learner and vendor onboarding creates pressure to skip access reviews and due-diligence steps, this should be governed through a Board-approved risk-appetite statement with hard onboarding gates monitored by the risk committee.

Second, the three-month deadline for the AI admissions tool conflicts with Compliance and the Innovation objective's own requirement for "documented human oversight," since a DPIA and bias testing cannot be rushed without defeating their purpose, this should be governed through a mandatory AI governance gate chaired by a cross-functional committee, discussed further in Sections 3 and 5.

Third, the 99.9% availability target can conflict with security hardening (e.g., enforcing MFA fleet-wide or closing the exposed storage container quickly), which should be governed through a Change Advisory Board empowered to pre-approve emergency security changes without deprioritising them for uptime optics.

A fourth, narrower conflict , operational efficiency versus segregation of duties in Finance is addressed as part of the risk register in Section 3.

2. Compliance Obligations Register

The Obligations tab of the workbook classifies each candidate framework rather than assuming all are legally mandatory. The Nigeria Data Protection Act (NDPA) 2023 clearly applies as law, since NexaLearn is a Nigerian data controller processing learner and staff personal data; it requires a lawful basis, DPIAs for high-risk processing, and breach notification to the NDPC within the statutory period. GDPR applies, but

only in respect of the roughly 600 EEA-resident learners, under the extraterritorial "offering services" test in Article 3(2); it requires Article 28 processor agreements, 72-hour breach notification, and consideration of an EU representative. PCI DSS is a contractual/industry obligation flowing from the payment-gateway relationship and card-brand rules rather than statute, and its scope should be confirmed against how much cardholder data NexaLearn's own systems actually touch.

ISO/IEC 27001 and ISO/IEC 42001 are certifiable standards that are voluntary in principle but become binding commitments the moment the Board sets them as targets, the Board has done exactly that for ISO/IEC 27001 (certification readiness) and, implicitly, for ISO/IEC 42001 by requiring "documented human oversight" of the AI tool. NIST CSF 2.0 is treated here purely as a voluntary organising reference for the CCF's control domains, not a certifiable or legally mandated standard. Finally, GDPR Article 22 on automated decision-making is flagged as conditionally applicable to the AI admissions tool for EEA applicants, and the ongoing, unnotified breach itself creates a live and overdue NDPA/GDPR obligation, tracked as O-08. No framework is described as mandatory beyond what the facts support.

Phase 2 - ALIGN: Set Direction and Ownership

3. Risk Register and Risk Appetite

Ten risks were derived from the scenario and evidence pack, scored on a 5x5 likelihood/impact scale (full definitions in the workbook). The three highest-rated risks are: R-03 (storage misconfiguration exposing ~1,240 learner records already realised, rated 25, Critical), R-01 (shared, MFA-exempt emergency-admin account, rated 20, Critical) and R-04 (absence of a formal breach-notification runbook, meaning the current incident remains unreported, also rated 20, Critical). R-02 (37-day delay in disabling a departed contractor's account, rated 16) and R-07 (the AI admissions tool deployed without documented human oversight, rated 15) are also High/Critical. Two risks address third parties directly: R-05 (weak data-processing clauses with the customer-support vendor, rated 12) and R-06 (unreviewed sub-processors and no exit plan, rated 9). The remaining risks:- R-08 (Finance segregation-of-duties conflict), R-09 (repeated late closure of audit findings) and R-10 (a stale, interactively-accessible service-account password) are all rated 12, Medium-High, and reinforce a common root cause: control execution, not control design, is the recurring failure mode across NexaLearn's environment.

The risk appetite statement (reproduced in the workbook) sets a low appetite for security and privacy risk ; no risk rated 15 or above may remain open past its target date without Board exception; a low-to-moderate appetite for availability risk, a moderate appetite for compliance risk during the ISO/IEC 27001 readiness programme provided gaps are owned and time-bound, and a moderate appetite for innovation risk that explicitly conditions AI deployment on demonstrated human oversight before go-live.

4. Three Lines of Defence and RACI Design

Responsibility is structured using the three-lines model: business-unit management and IT/development operations (first line) own day-to-day execution of access provisioning, storage configuration and support delivery; Risk, Compliance (including the Data Protection function) and Security (second line) set policy, own the CCF, and monitor indicators; Internal Audit (third line) provides independent assurance and escalates overdue findings, directly relevant given the scenario's own observation of "repeated late closure of access-review and backup-testing findings." The RACI matrix in the workbook assigns Responsible/Accountable for access management, incident response, privacy compliance and vendor risk to IT/Security and Risk/Compliance respectively, with the Board holding Accountable status specifically for AI governance go-live, reflecting its strategic and reputational significance.

Evidence A reveals two incompatible-duties findings. The Finance Officer's combination of refund approval and reconciliation access removes the natural check that would catch a fraudulent or erroneous refund, because the person who can approve a refund can also clear the reconciliation that would otherwise flag it; this is a textbook segregation-of-duties failure that should be remedied either by splitting the duties or, in a lean team, by requiring an independent second reviewer to sign off monthly reconciliations as a compensating control. The shared emergency-admin account used by the IT Manager and two developers is a related but distinct concern: it combines administrative privilege with development access in one unattributable identity and is protected by a standing MFA exemption, defeating both individual accountability and the very control meant to secure it.

Phase 3 - PERFORM: Design and Test Controls

5. Common Control Framework

Thirteen enterprise controls were designed across governance, identity and access management, data protection, incident response, third-party risk, business continuity, logging and monitoring, and AI governance (full detail, including owners, frequency and evidence, is in the CCF tab). Each control is mapped to at least two relevant obligations or frameworks, for example, C-02 (Privileged Access Management) maps to ISO/IEC 27001 Annex A controls 5.15/8.5 and NIST CSF 2.0's Protect function, while C-10 (the AI governance gate) maps to ISO/IEC 42001 and GDPR Article 22. A Control Inheritance note clarifies that NexaLearn inherits certain controls from its cloud and SaaS suppliers under a shared-responsibility model, physical security, infrastructure patching and platform-level encryption from the LMS host, Microsoft 365 and the payment gateway, but remains solely responsible for configuring identity, access and data classification on top of that infrastructure. The public storage-container exposure (R-03) is therefore a NexaLearn configuration failure, not a lapse by the cloud provider, and the support vendor's SOC 2 report provides assurance over its own environment only, not a substitute for NexaLearn's own contractual and monitoring controls.

6. Practical Control Testing

Three control tests were performed directly against the evidence pack. Test T-01 (privileged access and leaver deprovisioning) sampled the five accounts in Evidence A and found deficiencies in four of five: it usefully distinguishes a design failure (the emergency-admin account's MFA exemption is a formally sanctioned policy gap, so the control as designed is inadequate) from an operating failure (the offboarding checklist for t.okoro.vendor exists but was not executed within its own SLA). Test T-02 (incident detection, escalation and breach response) traced the 08:12 impossible-travel alert through to the still-outstanding regulator/learner notification, finding an operating failure: the escalation and monitoring capability exists, but ran 2 hours 18 minutes past a defensible SLA, and the notification step has not been executed at all. Test T-03 (third-party due diligence) reviewed the customer-support vendor's contract and found a design failure: NexaLearn's own vendor-contracting standard does not currently require a DPA, an exception review of assurance reports, or an exit plan as a condition of onboarding a data-processing vendor, making the gap systemic rather than a one-off oversight. Together, the three tests confirm that both design and operating effectiveness need attention, and that the design gap in third-party contracting is the most systemic of the three.

Phase 4 - REVIEW: Monitor and Improve

7. Dashboard, Assurance and Improvement Roadmap

The executive dashboard (Dashboard tab) tracks eight indicators spanning KRIs, KPIs and control-effectiveness measures: the percentage of privileged accounts without MFA, overdue leaver-access removals, mean time to escalate security alerts, overdue high-risk audit actions, vendor-review completion, backup/DR test pass rate, platform availability against the 99.9% target, and the proportion of AI admissions decisions with documented human review. Each indicator has a named owner, a defined threshold and a reporting frequency, so that the Board and Risk Committee can monitor real trends rather than point-in-time snapshots.

The 90-day action plan (Action Plan tab) is prioritised by risk rating and dependency. The single highest priority is A-04 , finalising the breach-notification runbook and completing the overdue notification for the current incident, due on Day 10, because an active, unreported breach carries immediate legal exposure. This is followed by A-01 (eliminate the shared emergency-admin account, enforce MFA) and A-09 (rotate and lock down the stale service account) by Day 15, then A-03 (enforce a private-by-default storage baseline) by Day 20. Actions with dependencies are sequenced accordingly: automating leaver deprovisioning (A-02) depends on the PAM foundation from A-01, and the AI governance gate (A-06, due Day 60) depends on the Board first approving a formal risk-appetite statement (A-10) that defines an acceptable AI risk threshold. This sequencing ensures NexaLearn addresses its most acute, already-realised exposures before investing in the medium-term ISO/IEC 27001 and AI-governance programmes.

Executive Decision Brief

To: The Board of Directors, NexaLearn Digital Services Limited

From: GRC Engineering Task Team

Re: Urgent risk exposure and decisions required

The Three Most Urgent Risks

- 1 A learner-data breach has already happened, around 1,240 learner records were briefly exposed publicly and downloaded from an unfamiliar location, and as of this report no regulator or affected learner has been told.
- 2 One shared "emergency" administrator login, used by three technical staff with no individual accountability and an exemption from multi-factor authentication, could give an attacker or a disgruntled insider almost unrestricted access to our systems.
- 3 A former contractor's system access stayed active for 37 days after they left, and our internal auditors have already flagged that similar findings keep closing late, this is a pattern, not a one-off.

The Most Important Governance Decision Required

The Board must decide, this week, to authorise immediate breach notification to Nigeria's data-protection regulator and, for our EU-resident learners, the relevant EU authority, and to approve a formal enterprise risk-appetite statement that gives management clear authority to fix security gaps even where it briefly affects convenience or uptime. Without this decision, remediation stays informal and slow, exactly as it has been.

Likely Regulatory Implications

Nigerian law (NDPA 2023) and EU law (GDPR) both require breach notification within defined windows, and both are already running late from the moment the exposure was confirmed. Continued delay increases the likelihood of regulatory penalties and removes our ability to demonstrate a good-faith, timely response, currently our strongest mitigating factor.

Investment Priorities for the Next 90 Days

Funding is recommended, in this order:

- 1 A privileged-access management tool to remove shared admin logins;
- 2 Automated on/off-boarding so departing staff and contractors lose access immediately, and;
- 3 Automated monitoring that flags misconfigured storage and slow security responses before they become incidents. These three investments address the risks above directly and build the foundation needed for the ISO/IEC 27001 certification the Board has already targeted.

Decision Requested

We ask the Board to approve, today:

- (a) immediate regulator and learner breach notification;
- (b) the enterprise risk-appetite statement, and ;
- (c) the proposed Day-10/Day-15/Day-20 remediation actions with named budget owners, with progress reported to the Board at 30, 60 and 90 days.